BTEUP EXAM NOTES | HINGLISH EDITION

Information Security

Unit 5: Standards, IT Act, Audit, Policies, Disaster Recovery and BCP

In notes ke baare me

Part A me har topic simple Hinglish me real-life example ke saath samjhaya hai, taaki beginner bhi zero se samajh sake.

Part B me important exam questions ke poore 5-marks wale answers Hinglish me diye hain.

Last me: quick revision sheet, common mistakes aur self-test.

Exam me answer English me likhna hai to English Edition PDF use karo.

Syllabus covered (Unit 5)

Introduction to Security Standards: ISO 27001, Indian IT Act, IPR Laws; Security Audit procedures; Developing Security Policies; Disaster Recovery, Business Continuity Planning.

Unit Overview aur Contents

Simple idea: Sirf technology se organization secure nahi hoti. Uske liye **rules** (standards aur policies), **laws** (IT Act, IPR), **checking** (security audit) aur bure waqt ka **backup plan** (disaster recovery aur business continuity) bhi chahiye. Ye unit security ka **management aur legal side** hai.

Topic	Exam importance	Notes me kahan
ISO 27001	Very High	Part A: Topic 1 | Part B: Q1, Q2
Indian IT Act	Very High	Part A: Topic 2 | Part B: Q3, Q4
IPR Laws	Very High	Part A: Topic 3 | Part B: Q5, Q6
Security Audit procedure	Very High	Part A: Topic 4 | Part B: Q7, Q8
Security Policies banana	High	Part A: Topic 5 | Part B: Q9, Q10
Disaster Recovery, BCP	Very High	Part A: Topic 6 | Part B: Q11, Q12

Contents

Part A: Easy Explanation	Part B: Important Questions aur Answers
Topic 1: Security Standards, ISO 27001 Topic 2: Indian IT Act Topic 3: IPR Laws Topic 4: Security Audit Topic 5: Security Policies Topic 6: DR aur BCP	Q1 ISO 27001 and ISMS (Very Likely) Q2 Annex A controls and certification (Likely) Q3 IT Act 2000 features (Very Likely) Q4 Cyber offences and punishments (Very Likely) Q5 IPR and its types (Very Likely) Q6 Copyright vs Patent vs Trademark (Likely) Q7 Security audit procedure (Very Likely) Q8 Types of security audit (Possible) Q9 Developing a security policy (Very Likely) Q10 Types of security policies (Likely) Q11 Business Continuity Planning (Very Likely) Q12 Disaster Recovery, RTO, RPO, BCP vs DR (Very Likely)

Is unit ko kaise padhein (time: 1 din)

1) Part A ek baar padh kar samjho. 2) Part B ke answers diagram ke saath copy me likh kar practice karo. 3) Quick Revision Sheet se revise karo. 4) Self-Test bina dekhe karo.

PART A: Easy Explanation (Hinglish)

Topic 1: Security Standards and ISO 27001

Real-life example

Standard ek **aisi recipe** jaisa hai jise saare achhe restaurants follow karte hain. Restaurant recipe follow kare aur inspector confirm kar de, to customers bharosa karte hain. Security standard information security ke liye wahi kaam karta hai.

Definition

Security standard best practices aur requirements ka documented set hai, jise organizations information ko consistent aur proven tarike se protect karne ke liye follow karti hain.

Standard / Law	Purpose
ISO/IEC 27001	Information Security Management System (ISMS) ka international standard
ISO/IEC 27002	Security controls ke guidelines (code of practice)
ISO 22301	Business Continuity Management System
PCI DSS	Payment card data ki security
NIST Cybersecurity Framework	US framework: Identify, Protect, Detect, Respond, Recover

ISO/IEC 27001

Definition

ISO/IEC 27001 wo international standard hai jo **Information Security Management System (ISMS)** ko **establish, implement, maintain aur continually improve** karne ki requirements batata hai. Current edition **ISO/IEC 27001:2022** hai.

- **ISMS** sensitive information ko manage karne ka systematic tarika hai, jisme people, processes aur technology risk assessment ke aadhar par manage hote hain.
- Ye **CIA triad** protect karta hai: Confidentiality, Integrity, Availability.
- Ye **PDCA** cycle follow karta hai: Plan, Do, Check, Act.
- **Clauses 4 se 10** me requirements hain: context, leadership, planning, support, operation, performance evaluation, improvement.
- **Annex A** me chaar themes me **93 controls** hain: Organizational (37), People (8), Physical (14), Technological (34). Purane 2013 edition me 14 domains me 114 controls the.
- Organization apne liye zaroori controls chunti hai aur unhe **Statement of Applicability (SoA)** me likhti hai.

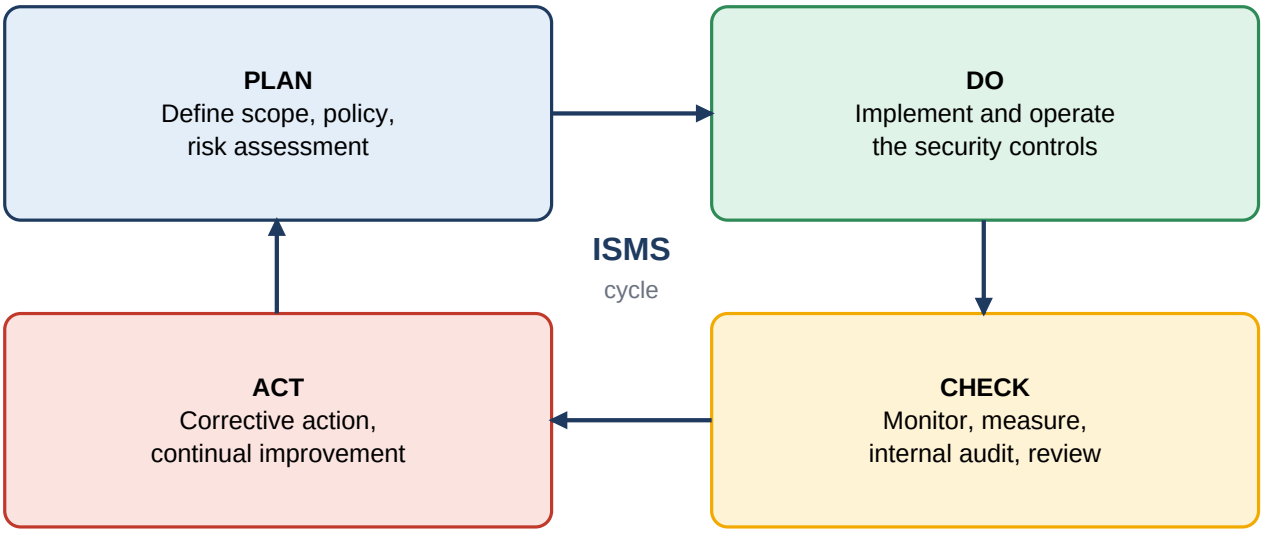


Figure 1: PDCA cycle of ISMS (ISO 27001)

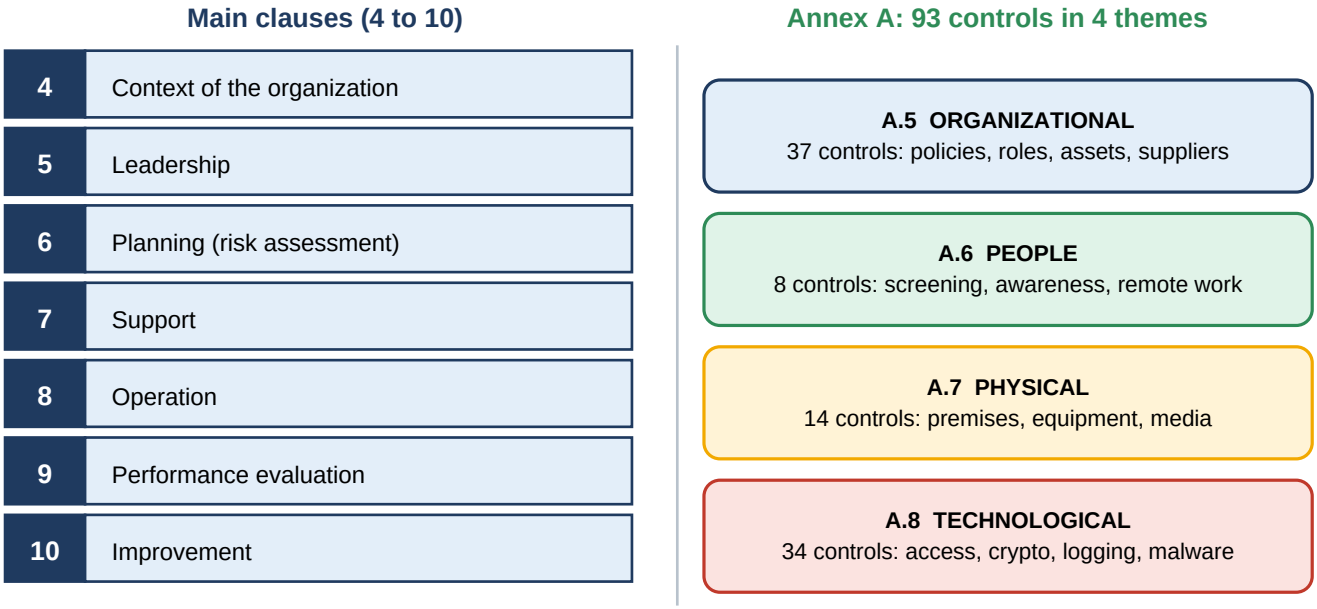


Figure 2: ISO 27001:2022 structure: clauses and Annex A

Certification aur benefits

- **Stage 1 audit:** auditor documents review karta hai. **Stage 2 audit:** auditor check karta hai ki controls sach me lagu hain.
- Certification body **3 saal** ke liye valid certificate deti hai, **saalana surveillance audits** ke saath, phir recertification.
- **Benefits:** customer ka bharosa, legal aur regulatory compliance, kam security incidents, behtar risk management, competitive advantage.

Topic 2: Indian IT Act

Real-life example

Traffic rules sadak par galat gaadi chalane walon ko saza dete hain. Isi tarah IT Act computers aur Internet ka galat use karne walon ko saza deta hai, aur **digital documents aur signatures ko legal value** bhi deta hai.

Definition

Information Technology Act, 2000 India ka main kanoon hai **cyber crime aur electronic commerce** ke liye. Ise **IT (Amendment) Act, 2008** se kaafi badla gaya.

Main objectives aur features

- **Electronic records aur digital signatures ko legal recognition** deta hai (Sections 4, 5), isliye e-contracts aur e-filing valid hain.
- **E-commerce aur e-governance** ko badhava deta hai.
- **Cyber offences** aur unki saza define karta hai (Sections 65 se 75).
- Digital signature certificates ke liye **Certifying Authorities** aur **Controller** banata hai.
- **CERT-In** (Section 70B) cyber incident response ki national agency hai.
- Poore India par lagu hota hai aur India ke computer se jude India ke bahar ke offences par bhi.

Important sections aur punishments

Section	Offence	Saza
43	Unauthorized access, data chori, virus, computer ko nuksan	Victim ko compensation (civil)
65	Computer source documents ke saath chhedchhad	3 saal tak ya Rs 2 lakh tak fine, ya dono
66	Computer-related offences (hacking: Sec 43 ka dishonest ya fraudulent kaam)	3 saal tak ya Rs 5 lakh tak fine, ya dono
66B	Chori ka computer ya device dishonestly lena	3 saal tak ya Rs 1 lakh tak fine, ya dono
66C	Identity theft (kisi ka password, e-signature use karna)	3 saal tak aur Rs 1 lakh tak fine
66D	Computer resource se personation karke dhokha	3 saal tak aur Rs 1 lakh tak fine
66E	Privacy ka ulanghan (private images lena)	3 saal tak ya Rs 2 lakh tak fine, ya dono
66F	Cyber terrorism	Umar qaid tak
67	Obscene material publish ya transmit karna	Pehli baar: 3 saal tak aur Rs 5 lakh tak fine. Dobara: 5 saal tak aur Rs 10 lakh
67A / 67B	Sexually explicit material / child sexual abuse material	Pehli baar: 5 saal tak aur Rs 10 lakh tak fine (dobara me zyada)
72	Confidentiality aur privacy ka ulanghan	2 saal tak ya Rs 1 lakh tak fine, ya dono

Jaanna zaroori hai

Section 66A (offensive messages bhejna) ko **Supreme Court ne 2015 me khatam kar diya** (Shreya Singhal case), isliye ab valid nahi hai. Section 43: compensation pehle Rs 1 crore tak limited tha; 2008 amendment ne ceiling hata di (kuch textbooks abhi bhi Rs 1 crore likhte hain). Naya **Digital Personal Data Protection Act, 2023** personal data par alag kanoon hai. Iske Rules November 2025 me notify hue aur main duties phases me, mukhya taur par May 2027 se, shuru hongi.

Topic 3: IPR Laws (Intellectual Property Rights)

Real-life example

Agar tum ghar banao to wo tumhari property hai aur koi use le nahi sakta. Isi tarah agar tum **gaana, software, invention ya brand** banao, to wo tumhari **intellectual property** hai, aur kanoon doosron ko use copy karne se rokta hai.

Definition

IPR wo legal rights hain jo kisi insaan ko uski **mind ki creations** (inventions, literary aur artistic works, designs, symbols, names) par milte hain, taaki owner unhe control kare aur unse kamaa sake.

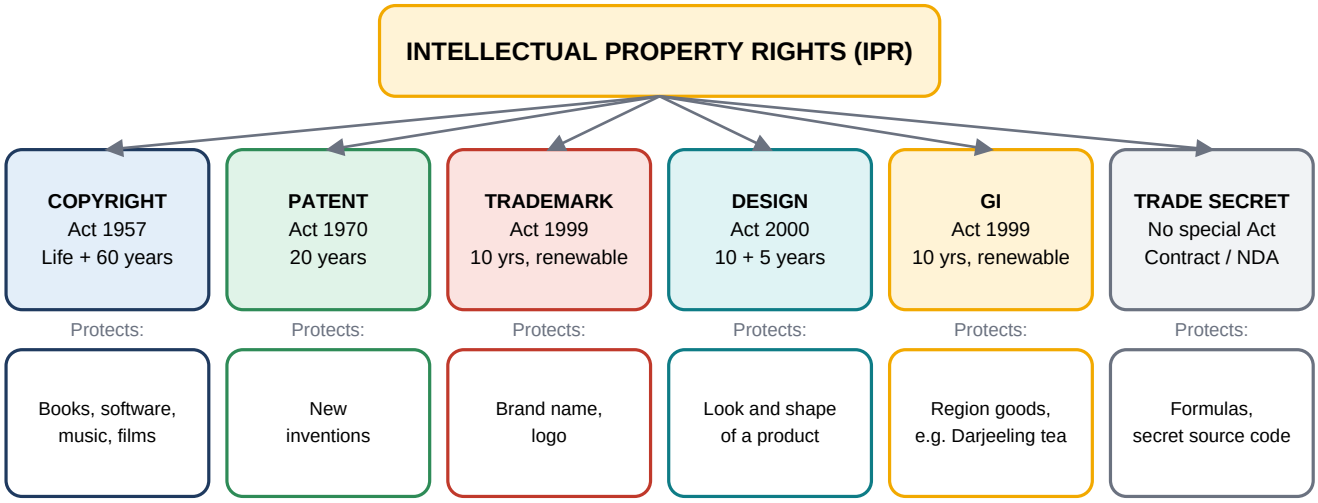


Figure 3: Types of IPR in India

IPR	Indian law	Protect karta hai	Duration
Copyright	Copyright Act, 1957	Books, music, films, **software**, art	Author ki life + 60 saal
Patent	Patents Act, 1970	Nayi, useful inventions	20 saal
Trademark	Trade Marks Act, 1999	Brand name, logo, slogan	10 saal, renewable
Design	Designs Act, 2000	Product ki shape, pattern, look	10 saal + 5 extension
Geographical Indication (GI)	GI Act, 1999	Region se jude goods (Darjeeling tea, Banarasi saree)	10 saal, renewable
Trade secret	Alag Act nahi	Secret formulas, business information	Jab tak secret rahe

IPR aur software

- **Software copyright se protect hota hai** literary work ki tarah. Pirated software copy ya bechna **software piracy** hai, jo Copyright Act ki Section 63 me punishable hai (6 mahine se 3 saal tak jail aur fine).
- **Computer program per se** India me patent nahi ho sakta (Patents Act ki Section 3(k)), par software use karne wala technical invention ho sakta hai.
- Open-source licences (GPL, MIT) users ko conditions ke saath code use aur modify karne ke rights dete hain.
- **Security se relation:** IPR laws source code, designs aur data ko chori se bachate hain, aur IT Act aise property ki cyber chori ko punish karta hai.

Topic 4: Security Audit Procedures

Real-life example

Security audit **health check-up** jaisa hai. Doctor tumhari history leta hai, tests karta hai, problems dhoondhta hai aur dawai ke saath report likhta hai. Baad me follow-up hota hai. Audit tumhare IT systems ke liye yahi karta hai.

Definition

Security audit organization ke information systems, policies aur controls ka systematic, independent evaluation hai, jisse check hota hai ki wo security policy, standards aur laws ko poora karte hain ya nahi, aur weaknesses dhoondhi jaati hain.

Security audit ke steps

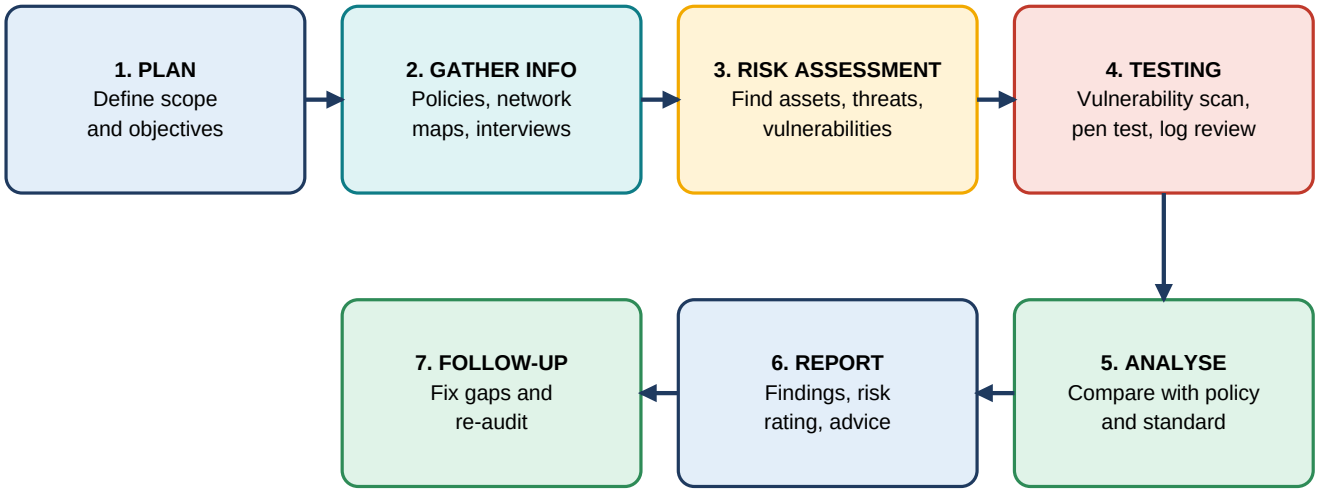


Figure 4: Security audit procedure

- **1. Planning aur scoping:** objectives, scope (kaunse systems), kaunse standards check honge, team aur schedule decide karo.
- **2. Information gathering:** policies, network diagrams, asset list jama karo; staff ke interviews; pichhle audits review karo.
- **3. Risk assessment:** assets, threats, vulnerabilities aur unka impact pehchano.
- **4. Testing:** vulnerability scanning, penetration testing, configuration aur log review, physical inspection.
- **5. Analysis:** results ko policy aur standard se compare karo; har finding ko risk ke hisab se rate karo.
- **6. Reporting:** findings, risk ratings aur recommendations ke saath report banao; management ko present karo.
- **7. Follow-up:** gaps fix karo (remediation) aur confirm karne ke liye re-audit karo.

Audit ke types aur areas

Type	Matlab
Internal audit	Organization ke apne staff dwara
External audit	Independent third party / certification body dwara
Compliance audit	Standard ya law (ISO 27001, IT Act) ke compliance ko check karta hai
Technical audit	Systems, networks aur applications test karta hai (scans, pen tests)

- **Areas jo check hote hain:** physical security, access control aur passwords, network aur firewall, operating systems, applications, backups, logs, policies aur staff awareness.

- **Tools:** Nmap, Nessus, OpenVAS (scanners), Wireshark, Metasploit (testing), log analyzers.

Topic 5: Developing Security Policies

Real-life example

School ke rules hote hain: uniform pehno, class me mobile nahi. Sabko pata hota hai kya allowed hai aur rule todne par kya hoga. Security policy organization ka **information protect karne ka rulebook** hai.

Definition

Security policy ek formal, written document hai, jo management se approved hota hai, aur batata hai ki **kya protect karna hai, zimmedari kiski hai, aur sabko kaunse rules follow karne hain**.

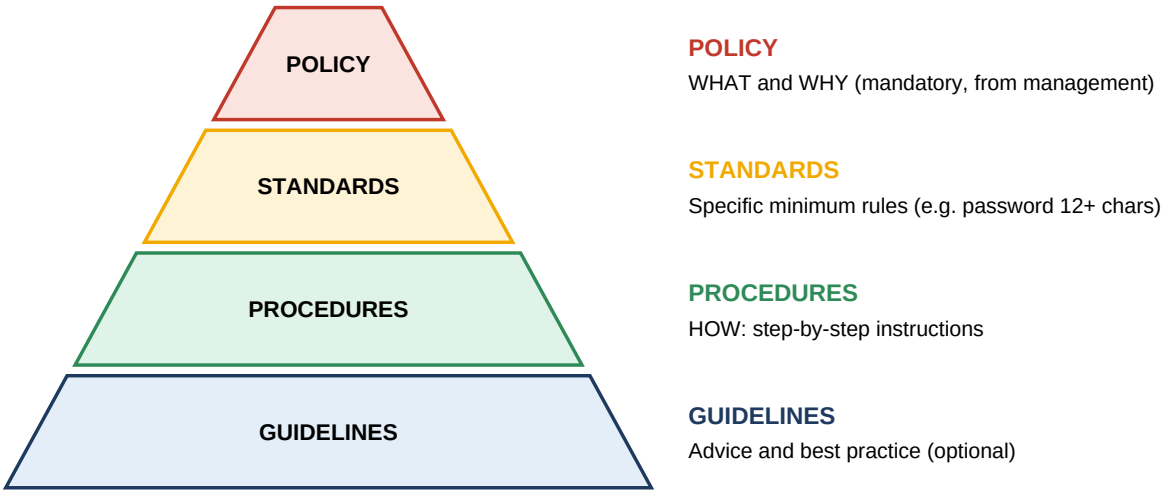


Figure 5: Policy, standards, procedures and guidelines

Security policy banane ke steps

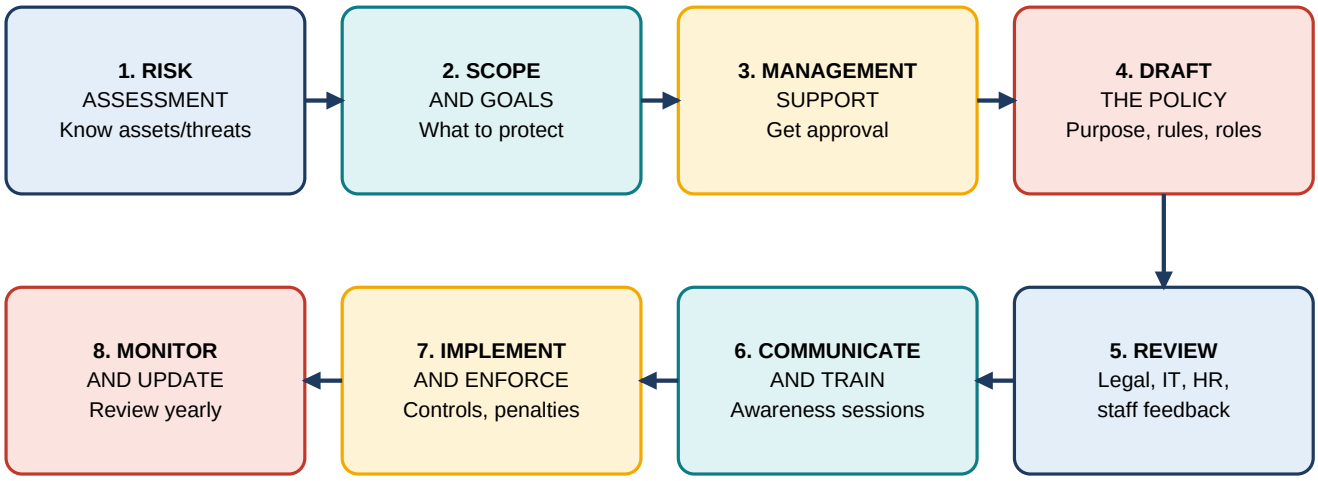


Figure 6: Developing a security policy

- **1. Risk assessment:** apne assets, threats aur legal needs jaano.
- **2. Scope aur goals:** decide karo policy kya cover karegi aur kya achieve karegi.
- **3. Management support:** top management policy ko approve aur support kare.
- **4. Draft:** purpose, scope, roles aur responsibilities, rules, violation ki saza likho.
- **5. Review:** IT, legal, HR aur users se feedback lo.
- **6. Communicate aur train:** har employee use padhe aur samjhe.
- **7. Implement aur enforce:** technical controls lagao aur violations par action lo.
- **8. Monitor aur update:** kam se kam saalana ya incident ke baad review karo.

Achhi policy ki khoobiyaan

- Clear aur simple, realistic aur enforceable, management se approved, flexible, regularly reviewed, aur ISO 27001 jaise laws aur standards ke saath aligned.

Security policies ke common types

Policy	Kya cover karti hai
Acceptable Use Policy (AUP)	Employees computers, email aur Internet kaise use kar sakte hain
Password policy	Length, complexity, change period, sharing nahi
Access control policy	Kaun kya access kar sakta hai (least privilege)
Email and Internet policy	Safe email use, phishing, personal use ki limits
Backup and retention policy	Kya backup hoga, kitni baar, kitne time tak
Incident response policy	Security incidents kaise report aur handle hon
Remote access / BYOD policy	VPN aur personal devices ka use
Physical security policy	Entry control, visitors, equipment protection

Topic 6: Disaster Recovery and Business Continuity Planning

Real-life example

Socho barish me dukaan me paani bhar gaya. **Business Continuity** wo plan hai jisse bikri chalti rahe (doosri dukaan, customers ko batana, staff ko salary). **Disaster Recovery** wo plan hai jisse computers theek ho aur records wapas aayen.

Definition

Business Continuity Plan (BCP) wo plan hai jo disaster ya disruption ke dauran aur baad me **critical business functions ko chalu rakhta** hai. **Disaster Recovery Plan (DRP)** uska wo hissa hai jo disaster ke baad **IT systems, data aur network ko restore** karne par focus karta hai.

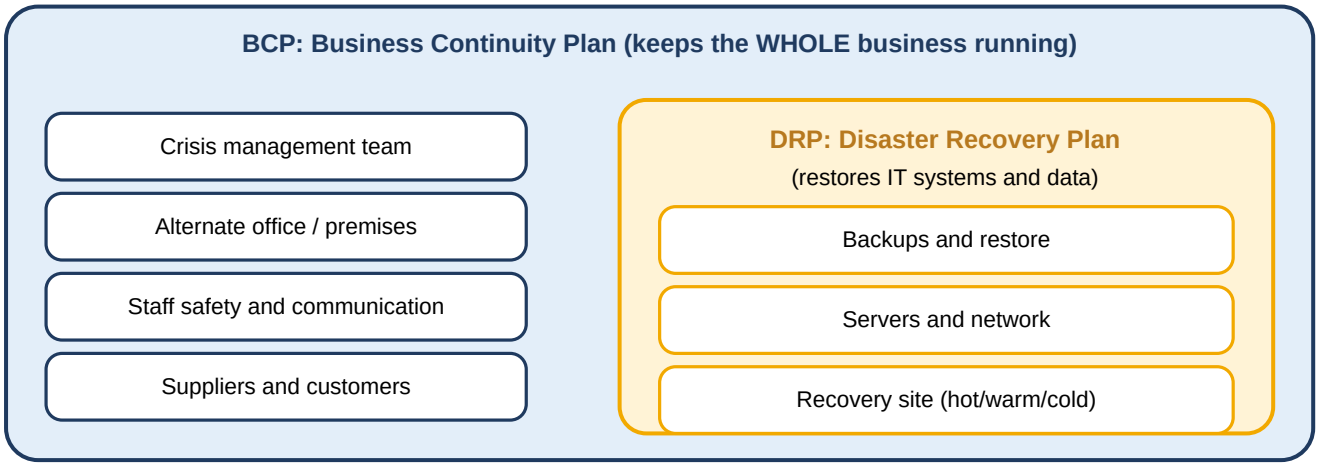


Figure 7: BCP and DRP

Disasters ye ho sakte hain

- **Natural:** baadh, bhukamp, aag, toofan. **Technical:** hardware failure, power cut, software bug, ransomware, cyber attack. **Human:** galtiyan, sabotage, chori, strike.

Business Continuity Planning ke steps

- **1. Project initiation:** management approval lo, team banao, scope define karo.
- **2. Business Impact Analysis (BIA):** critical processes pehchano, wo kitni der band reh sakte hain, aur downtime se nuksan kitna hoga.
- **3. Risk assessment:** threats aur unki sambhavna pehchano.
- **4. Strategy:** recovery strategies chuno (backups, alternate site, spare equipment).
- **5. Plan development:** roles, contact lists aur step-by-step actions ke saath BCP aur DRP likho.
- **6. Testing aur training:** walkthroughs, simulations, full drills; staff ko train karo.
- **7. Maintenance:** plan ko regularly review aur update karo.

Important terms: RTO, RPO, MTD

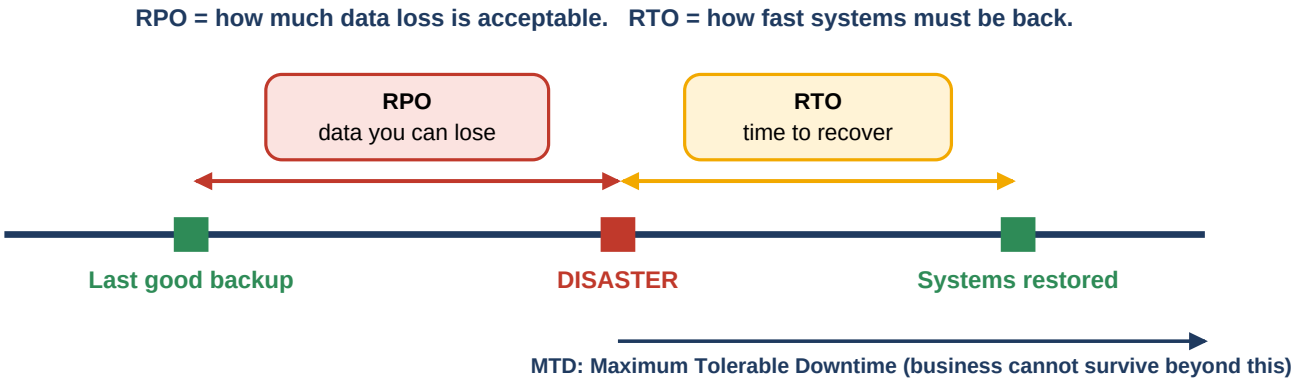


Figure 8: RPO, RTO and MTD

- **RPO (Recovery Point Objective):** maximum data loss jo acceptable hai, time me naapa jaata hai. RPO 1 ghanta hai to backup kam se kam har ghante lena hoga.
- **RTO (Recovery Time Objective):** disaster ke baad system restore karne ka maximum allowed time.
- **MTD (Maximum Tolerable Downtime):** sabse lamba outage jo business jhel sakta hai. RTO, MTD se kam hona chahiye.

Disaster recovery strategies

- **Backups: Full** (sab kuch copy), **Incremental** (pichhle kisi bhi backup ke baad ke changes), **Differential** (pichhle full backup ke baad ke changes).
- **3-2-1 rule:** data ki 3 copies, 2 alag media par, 1 copy off-site.
- **Recovery sites:** hot, warm aur cold sites (figure dekho).
- **Other:** data replication, cloud backup, UPS aur generator, RAID, spare hardware.



Figure 9: Hot, warm and cold recovery sites

Point	BCP	DRP
Focus	Poore business operations	IT systems aur data
Scope	Zyada wide (people, premises, process)	Chhota (technology)
Aim	Business chalta rakhna	Disaster ke baad IT restore karna
Timing	Pehle, dauran aur baad me	Mukhya taur par disaster ke baad

PART B: Important Questions aur Model Answers (Hinglish)

Priority: **Very Likely** = BTEUP me sabse zyada aata hai. **Likely** = achha chance. **Possible** = aa sakta hai. Har answer exam format me hai: **Definition, Points, Diagram/Table, Conclusion**.

Q1. ISO 27001 kya hai? Uska structure aur PDCA cycle explain karo. — VERY LIKELY

Definition / Parichay: ISO/IEC 27001 wo international standard hai jo Information Security Management System (ISMS) ko establish, implement, maintain aur continually improve karne ki requirements batata hai. Current edition ISO/IEC 27001:2022 hai.

Points

- **ISMS:** risk-based, systematic tarika jisme people, processes aur technology ko manage karke Confidentiality, Integrity aur Availability protect ki jaati hai.
- **Clauses 4 se 10:** context of the organization, leadership, planning (risk assessment aur treatment), support, operation, performance evaluation, improvement.
- **Annex A:** chaar themes me 93 controls (Organizational 37, People 8, Physical 14, Technological 34), jo Statement of Applicability me likhe jaate hain.
- **PDCA:** Plan (scope, policy, risk assessment), Do (controls implement), Check (monitor, internal audit, review), Act (corrective action, improvement).
- **Benefits:** customer ka bharosa, legal compliance, kam incidents, behtar risk management.

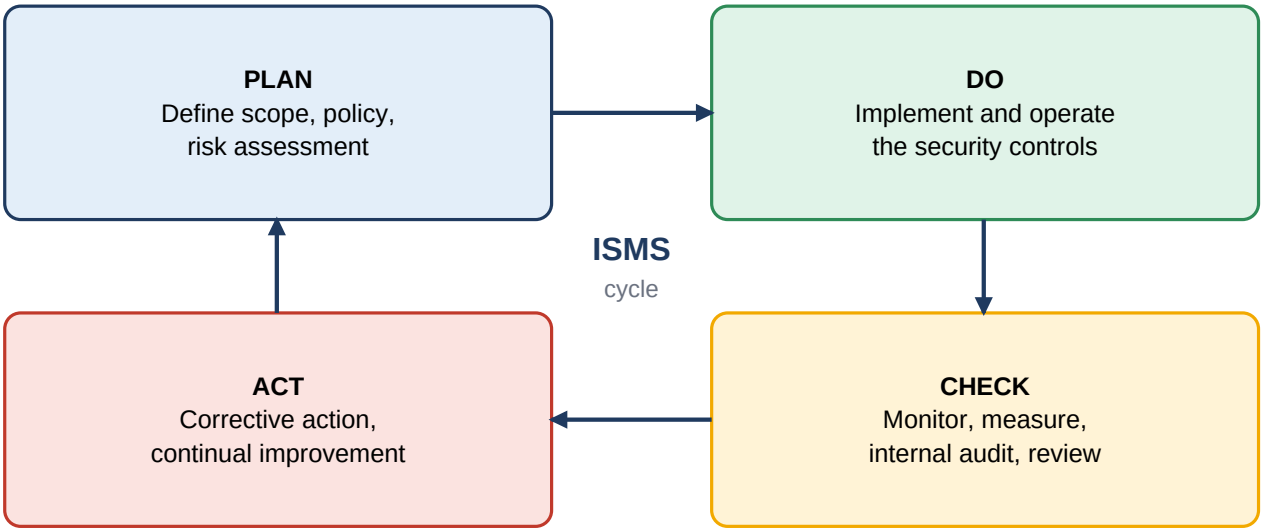


Figure: PDCA cycle of ISMS

Conclusion: ISO 27001 organizations ko information security manage karne ka proven framework deta hai aur certification se use prove karne ka mauka bhi.

Q2. ISO 27001 ke Annex A controls aur certification process explain karo. LIKELY

Definition / Parichay: ISO/IEC 27001:2022 ka Annex A 93 information security controls ki list hai, jisme se organization wo controls chunti hai jo uske pehchane hue risks ko handle karte hain.

Points

- **Organizational (A.5):** 37 controls jaise policies, roles, asset management, supplier relationships.
- **People (A.6):** 8 controls jaise screening, awareness training, remote working.
- **Physical (A.7):** 14 controls jaise secure areas, equipment protection, media disposal.
- **Technological (A.8):** 34 controls jaise access control, cryptography, logging, malware protection, secure coding.
- **Certification:** Stage 1 (document review), Stage 2 (implementation audit), certificate 3 saal valid, saalana surveillance audits ke saath, phir recertification.

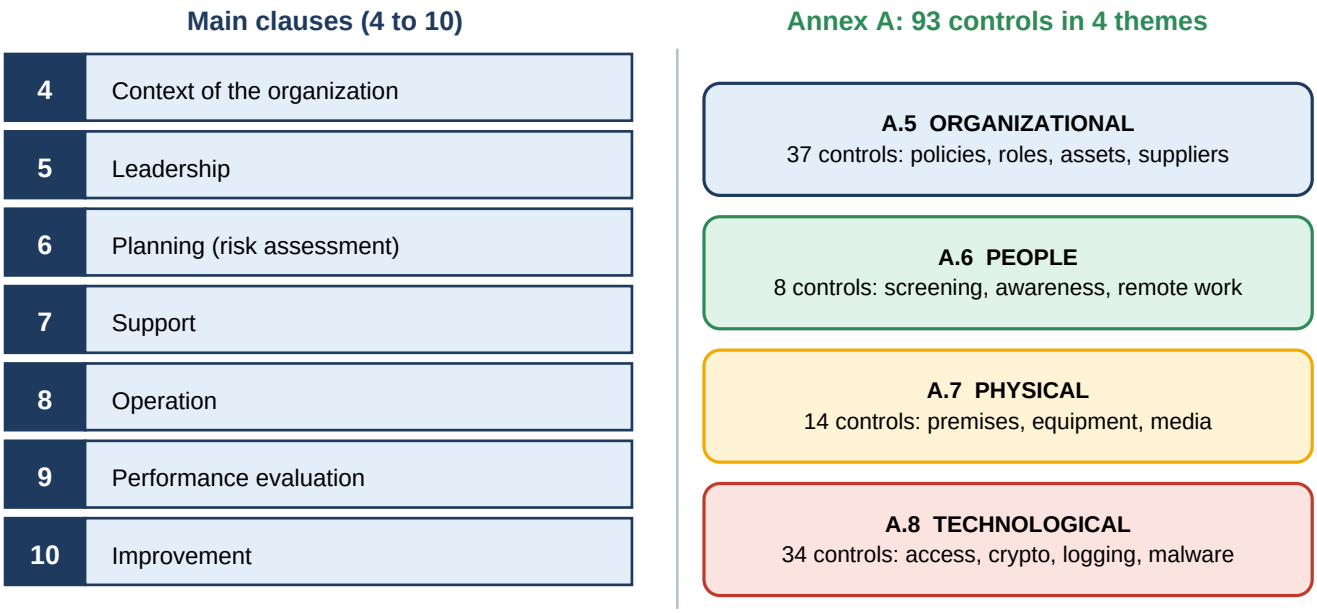


Figure: ISO 27001:2022 clauses and Annex A

Conclusion: Sahi controls chun kar certification lene se customers aur regulators ko dikhta hai ki information securely manage ho rahi hai.

Q3. Information Technology Act, 2000 aur uske main features explain karo. VERY LIKELY

Definition / Parichay: Information Technology Act, 2000 India ka main kanoon hai jo cyber crime aur electronic commerce se juda hai. Ise IT (Amendment) Act, 2008 se kaafi badla gaya.

Points

- Electronic records aur digital signatures ko **legal recognition** (Sections 4 aur 5), isliye e-contracts, e-filing aur e-governance valid hain.
- **Cyber offences aur saza:** hacking, identity theft, personation se dhokha, privacy violation, cyber terrorism, obscene content (Sections 65 se 67).
- **Section 43:** unauthorized access, data chori ya virus nuksan par victim ko compensation. **Section 43A:** company sensitive data protect na kare to compensation.
- **Certifying Authorities** aur Controller digital signature certificates ko license aur regulate karte hain.
- **CERT-In (Section 70B)** cyber incidents handle karta hai; Section 69 lawful interception allow karta hai; Section 70 critical information infrastructure ko protect karta hai.
- Ye poore India par aur India ke computer se jude India ke bahar ke offences par lagu hota hai. Section 66A ko Supreme Court ne 2015 me khatam kar diya.

Conclusion: IT Act India me e-commerce ki legal buniyaad hai aur cyber crime ko punish karne ka kanoon bhi.

Q4. IT Act ke under cyber offences aur unki saza likho. VERY LIKELY

Definition / Parichay: IT Act, 2000 (2008 me amended) kai cyber offences define karta hai aur har ek ke liye jail aur/ya fine batata hai.

Points

- **Section 65:** computer source documents ke saath chhedchhad. **Section 66:** hacking (Section 43 ka dishonest ya fraudulent kaam).
- **Section 66C:** identity theft. **Section 66D:** personation se dhokha. **Section 66E:** privacy ka ulanghan.
- **Section 66F:** cyber terrorism, jiski saza umar qaid hai.
- **Sections 67, 67A, 67B:** obscene, sexually explicit aur child abuse material.
- **Section 72:** confidentiality aur privacy ka ulanghan.

Section	Offence	Saza
65	Source documents se chhedchhad	3 saal / Rs 2 lakh / dono
66	Hacking	3 saal / Rs 5 lakh / dono
66C	Identity theft	3 saal aur Rs 1 lakh
66D	Personation se dhokha	3 saal aur Rs 1 lakh
66E	Privacy ka ulanghan	3 saal / Rs 2 lakh / dono
66F	Cyber terrorism	Umar qaid
67	Obscene material	Pehli baar: 3 saal aur Rs 5 lakh. Dobara: 5 saal aur Rs 10 lakh
72	Confidentiality ka ulanghan	2 saal / Rs 1 lakh / dono

Conclusion: Ye provisions cyber crime ko rokte hain aur victims ko legal remedy dete hain.

Q5. IPR kya hai? IPR ke types explain karo. VERY LIKELY

Definition / Parichay: Intellectual Property Rights (IPR) wo legal rights hain jo kisi insaan ko uski mind ki creations, jaise inventions, literary aur artistic works, designs, symbols aur names, par milte hain.

Points

- **Copyright** (Copyright Act, 1957): books, music, films aur software ko protect karta hai; author ki life + 60 saal.
- **Patent** (Patents Act, 1970): nayi inventions ko protect karta hai; 20 saal.
- **Trademark** (Trade Marks Act, 1999): brand names aur logos ko protect karta hai; 10 saal, renewable.
- **Design** (Designs Act, 2000): product ke look ko protect karta hai; 10 saal + 5.
- **Geographical Indication** (GI Act, 1999): Darjeeling tea jaise region-based goods; 10 saal, renewable.
- **Trade secret:** secret business information jo contracts aur NDAs se protect hoti hai.

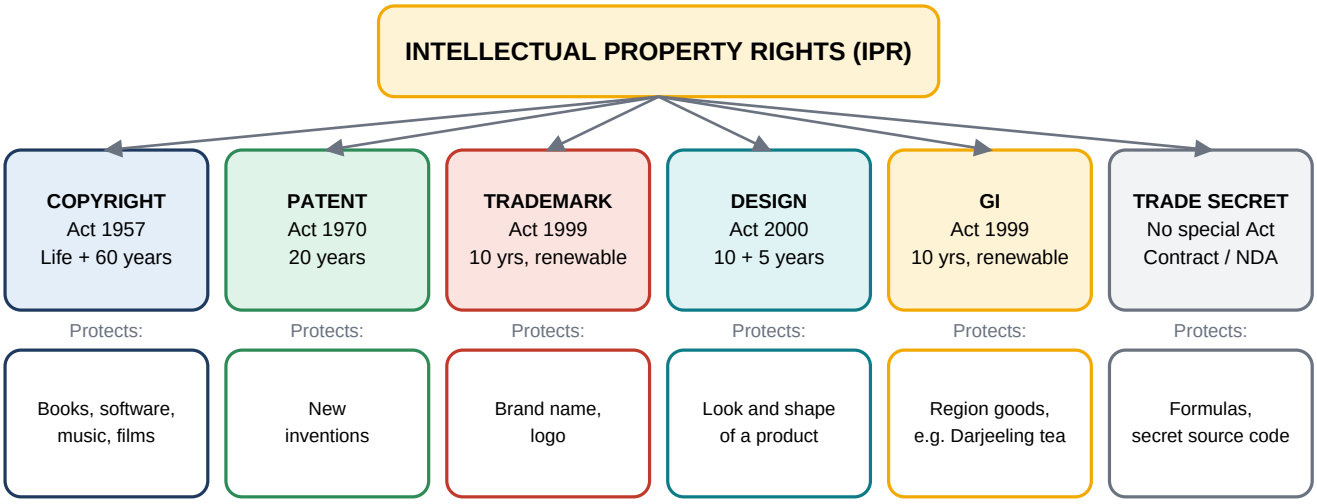


Figure: Types of IPR in India

Conclusion: IPR laws creators ko unke kaam par control aur kamaai ka haq dekar creativity ko badhava dete hain.

Q6. Copyright, Patent aur Trademark me difference likho. LIKELY

Definition / Parichay: Copyright, patent aur trademark IPR ke teen main forms hain, jo alag alag tarah ki creations ko protect karte hain.

Points

- Software copyright se protect hota hai; computer program per se India me patentable nahi (Section 3(k)).

Point	Copyright	Patent	Trademark
Protects	Original works: books, music, software	Nayi inventions	Brand name, logo, slogan
Indian law	Copyright Act, 1957	Patents Act, 1970	Trade Marks Act, 1999
Duration	Life + 60 saal	20 saal	10 saal, renewable
Registration	Automatic (registration optional)	Apply karna aur grant hona zaroori	Registration se strong rights
Example	Novel, mobile app	Naya engine design	Nike ka swoosh

Conclusion: Har IPR creation ke alag pehlu ko protect karta hai, aur ek product ko ek se zyada IPR chahiye ho sakte hain.

Q7. Security audit procedure explain karo. VERY LIKELY

Definition / Parichay: Security audit organization ke information systems, policies aur controls ka systematic, independent evaluation hai, jisse security policy, standards aur laws ka compliance check hota hai aur weaknesses dhoondhi jaati hain.

Points

- **Planning aur scoping:** objectives, scope, standards aur schedule define karo.
- **Information gathering:** policies, network diagrams, asset lists, staff interviews.
- **Risk assessment:** assets, threats aur vulnerabilities pehchano.
- **Testing:** vulnerability scan, penetration test, log aur configuration review, physical inspection.
- **Analysis, reporting:** policy se compare karo, risks rate karo, recommendations ke saath report banao.
- **Follow-up:** gaps fix karo aur re-audit karo.

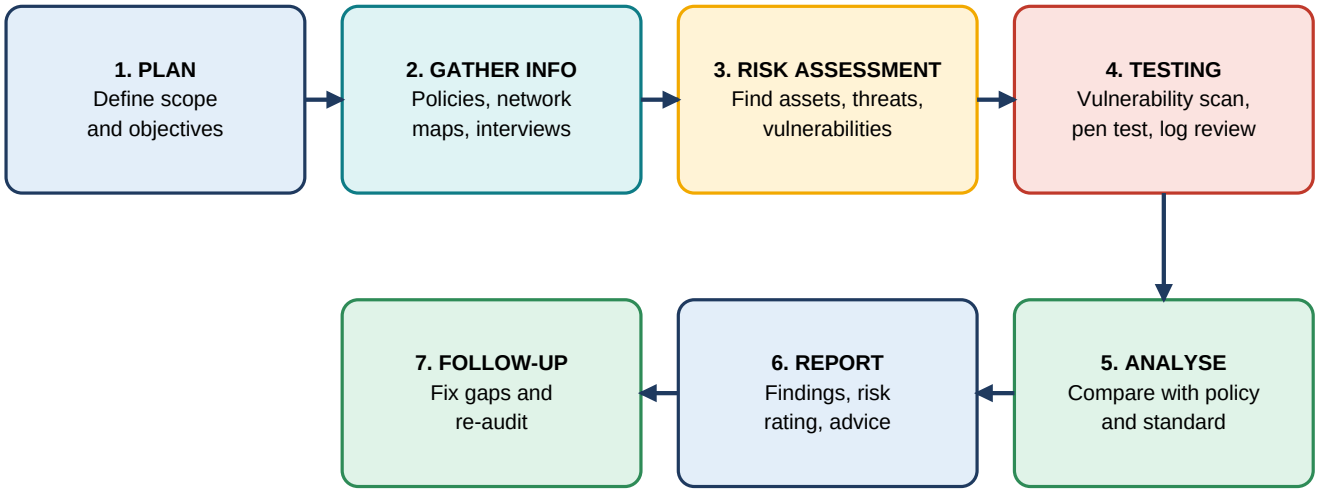


Figure: Security audit procedure

Conclusion: Regular security audits attackers se pehle weaknesses dhoondh lete hain aur management aur regulators ko compliance prove karte hain.

Q8. Security audit ke types explain karo. POSSIBLE

Definition / Parichay: Security audits ko is aadhar par baanta jaata hai ki unhe kaun karta hai aur wo kya check karte hain.

Points

- **Internal audit:** organization ke apne staff dwara; baar baar aur sasta, par kam independent ho sakta hai.
- **External audit:** independent third party ya certification body dwara; zyada objective aur certification ke liye zaroori.
- **Compliance audit:** ISO 27001 ya IT Act jaise standard ya law ke compliance ko check karta hai.
- **Technical audit:** scanners aur penetration tests se systems, networks aur applications test karta hai.

Type	Kaun karta hai	Main purpose
Internal	Apna staff	Self-check, improvement
External	Independent third party	Objective view, certification
Compliance	Internal ya external	Standard / law compliance
Technical	Security specialists	Technical vulnerabilities dhoondhna

Conclusion: Internal aur external dono audits use karne se sabse achhi assurance milti hai.

Q9. Security policy kaise develop hoti hai? Steps explain karo. VERY LIKELY

Definition / Parichay: Security policy ek formal written document hai, jo management se approved hota hai, aur batata hai ki kya protect karna hai, zimmedari kiski hai aur sabko kaunse rules follow karne hain.

Points

- **Risk assessment:** assets, threats aur legal requirements pehchano.
- **Scope aur goals:** decide karo policy kya cover karegi.
- **Management support:** top management se approval lo.
- **Draft:** purpose, scope, roles, rules aur penalties.
- **Review:** IT, legal, HR aur users ka feedback.
- Sabhi employees ko **communicate aur train** karo.
- Technical controls aur disciplinary action ke saath **implement aur enforce** karo.
- Regularly **monitor aur update** karo, kam se kam saalana.

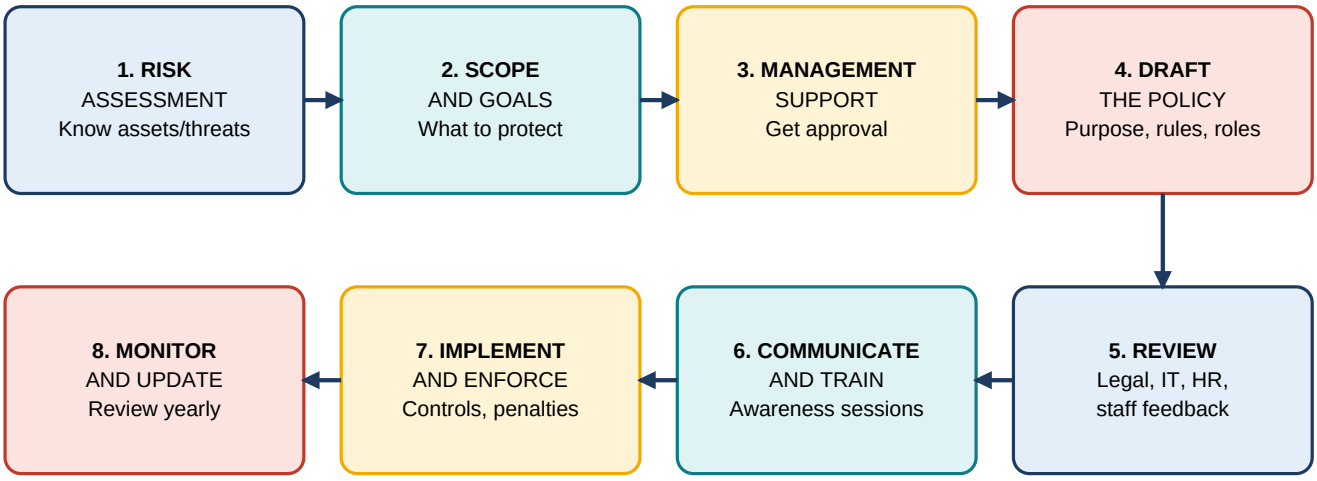


Figure: Steps in developing a security policy

Conclusion: Achhi tarah banayi gayi, enforce ki gayi aur regularly update hoti policy organization ki security ki buniyaad hai.

Q10. Alag alag types ki security policies explain karo. LIKELY

Definition / Parichay: Organizations security ke alag alag areas ke liye alag policies likhti hain, jinhe standards, procedures aur guidelines support karte hain.

Points

- **Acceptable Use Policy (AUP):** staff computers, email aur Internet kaise use kar sakta hai.
- **Password policy:** minimum length, complexity, expiry, sharing nahi.
- **Access control policy:** least privilege aur kaun kya access kar sakta hai.
- **Backup policy:** data kya, kitni baar aur kitne time tak backup hoga.
- **Incident response policy:** incidents kaise report aur handle hon.
- **Remote access / BYOD policy** aur **physical security policy**.

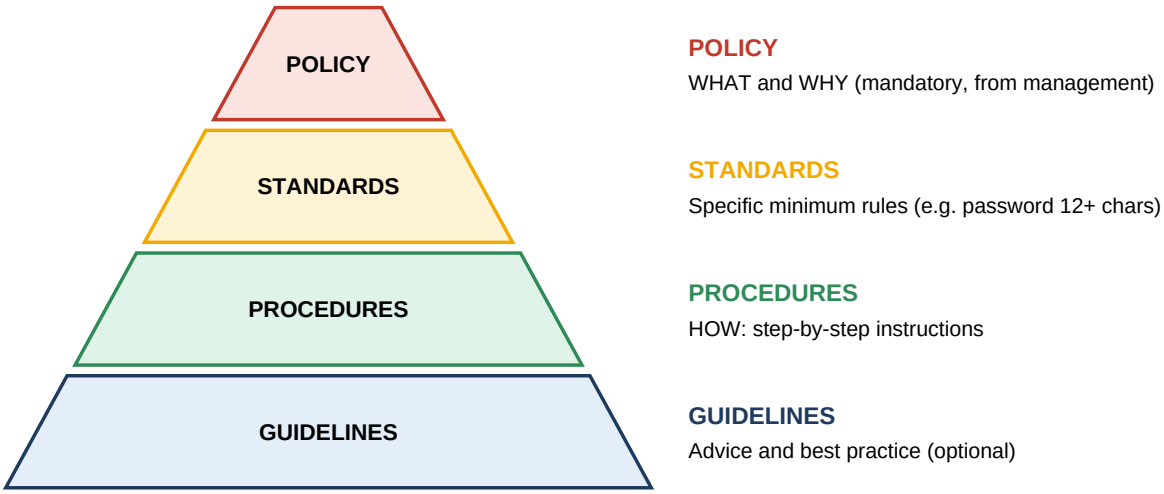


Figure: Policy, standards, procedures, guidelines

Conclusion: Ye policies milkar people, technology aur processes ko cover karti hain.

Q11. Business Continuity Planning kya hai? Uske steps explain karo. VERY LIKELY

Definition / Parichay: Business Continuity Planning (BCP) wo process hai jisme aisa plan banaya jaata hai jo disaster ya disruption ke dauran aur baad me critical business functions ko chalu rakhe.

Points

- **Project initiation:** management approval, team aur scope.
- **Business Impact Analysis (BIA):** critical processes, allowed downtime aur downtime ki cost pehchano.
- **Risk assessment:** fire, flood, cyber attack, power failure jaise threats.
- **Strategy:** backups, alternate site, spare equipment, manual workarounds.
- **Plan development:** roles aur contact lists ke saath BCP aur DRP likho.
- **Testing aur training:** walkthrough, simulation aur full drill.
- **Maintenance:** regularly review aur update karo.

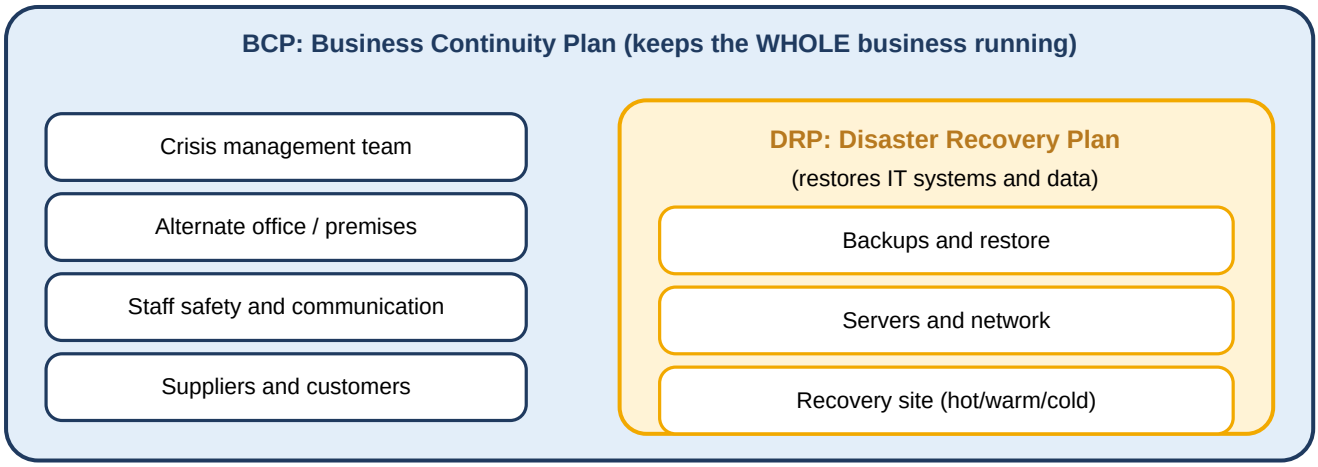


Figure: BCP and DRP

Conclusion: Tested BCP disaster ke time downtime, financial loss aur reputation ke nuksan ko kam karta hai.

Q12. Disaster Recovery kya hai? RTO, RPO aur recovery sites explain karo. BCP aur DR me difference likho.

VERY LIKELY

Definition / Parichay: Disaster Recovery (DR) un policies aur procedures ka set hai jo disaster ke baad IT systems, data aur network ko restore karte hain. Ye business continuity ka hissa hai.

Points

- **RPO:** maximum acceptable data loss, time me; backup frequency decide karta hai.
- **RTO:** system restore karne ka maximum allowed time; **MTD** sabse lamba outage hai jo business jhel sakta hai.
- **Backups:** full, incremental, differential; 3-2-1 rule follow karo.
- **Hot site:** poori tarah equipped, live data, minutes se ghanton me recovery, bahut mehnga. **Warm site:** hardware ready, data backup se restore, ghante se din. **Cold site:** sirf khali jagah aur power, din se hafte, sabse sasta.

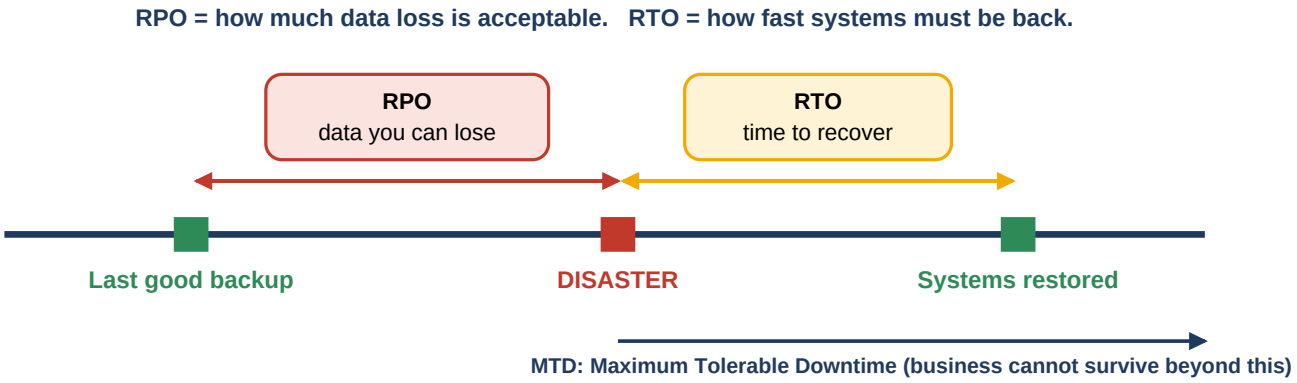


Figure: RPO, RTO and MTD

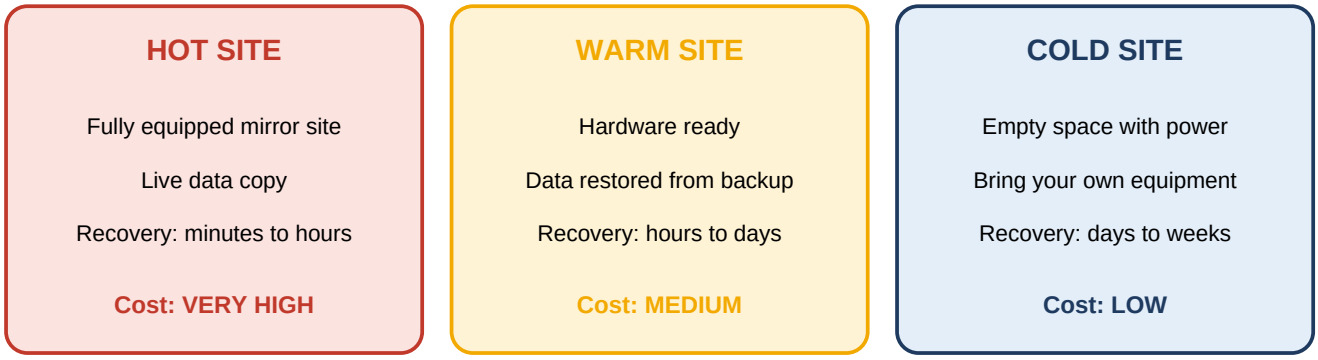


Figure: Hot, warm and cold sites

Point	BCP	DRP
Focus	Poora business	IT systems aur data
Scope	Zyada wide	Chhota
Aim	Business chalta rakhna	Disaster ke baad IT restore karna
Timing	Pehle, dauran, baad me	Mukhya taur par baad me

Conclusion: BCP business ko zinda rakhta hai aur DR technology wapas laata hai; dono milkar resilience dete hain.

Quick Revision Sheet (exam se pehle raat ko padho)

Term	Ye yaad rakho
ISO 27001	ISMS standard. Edition 2022. PDCA. Clauses 4-10
Annex A (2022)	93 controls: Org 37, People 8, Physical 14, Tech 34
Certification	Stage 1, Stage 2, 3 saal valid, saalana surveillance
IT Act	2000, amended 2008. E-records aur digital signatures ko legal value
Sec 43 / 65 / 66	Compensation / source docs 3 saal, Rs 2 lakh / hacking 3 saal, Rs 5 lakh
Sec 66C / 66D / 66E	Identity theft / personation / privacy: 3 saal
Sec 66F / 67	Cyber terrorism: umar qaid / obscene: 3 saal + Rs 5 lakh (pehli baar)
Sec 66A	2015 me Supreme Court ne khatam kiya
CERT-In	Sec 70B, national cyber incident agency
IPR durations	Copyright life+60, Patent 20, Trademark 10, Design 10+5, GI 10
Software IPR	Copyright protect karta hai. Sec 63 piracy. Sec 3(k): program per se patentable nahi
Audit steps	Plan, Gather, Risk, Test, Analyse, Report, Follow-up
Policy steps	Risk, Scope, Approval, Draft, Review, Train, Enforce, Update
Policy hierarchy	Policy > Standards > Procedures > Guidelines
BCP vs DR	Poora business vs IT recovery
RPO / RTO / MTD	Data loss limit / recovery time / max outage (RTO < MTD)
Sites	Hot (fast, mehnga), Warm, Cold (slow, sasta)
Backups / 3-2-1	Full, Incremental, Differential / 3 copies, 2 media, 1 off-site

Yaad rakhne ke tricks

Annex A numbers: 37-8-14-34 = Org, People, Physical, Tech (total 93).
IT Act 3-saal ke offences: 65, 66, 66B, 66C, 66D, 66E sab **3 saal tak**. Fine: 66 = 5 lakh, 65 aur 66E = 2 lakh, baaki = 1 lakh.
IPR saal: Copyright life ke baad **60**, Patent **20**, Trademark **10**, Design **10+5**.
RPO = Past (data), RTO = Time (recover karne ka).

Common Mistakes jo Students Karte Hain

- ISO 27001 ke 114 controls likhna. Current 2022 edition me **93** hain (114 2013 edition me the).
- **RPO** (data loss) aur **RTO** (recovery time) ko mix karna.
- BCP aur DR ko same samajhna. DR sirf BCP ka IT part hai.
- **Section 66A** ko valid likhna. Ise 2015 me khatam kar diya gaya.
- Software seedha patent ho sakta hai, aisa likhna. Wo **copyright** se protect hota hai.
- Policy ko technical steps ki tarah likhna. **Policy kya aur kyun** batati hai; procedure kaise batata hai.
- Diagrams na banana (PDCA, audit flow, RPO/RTO, hot/warm/cold sites).

Self-Test (bina dekhe likho, har question 5 marks)

- ISO 27001 kya hai? PDCA cycle diagram ke saath explain karo.
- IT Act ke koi chaar cyber offences section numbers aur saza ke saath likho.
- IPR ke types unki duration ke saath likho.
- Security audit ke steps explain karo.
- BCP aur DR me difference likho. RTO aur RPO kya hain?

Self-Test Answers (likhne ke baad check karo)

1. ISO/IEC 27001 ISMS ka international standard hai. PDCA: Plan (scope, policy, risk assessment), Do (controls implement), Check (monitor, audit, review), Act (corrective action, improvement). Figure 1 banao.

2. Example: Sec 66 hacking (3 saal / Rs 5 lakh), Sec 66C identity theft (3 saal aur Rs 1 lakh), Sec 66D personation se dhokha (3 saal aur Rs 1 lakh), Sec 66F cyber terrorism (umar qaid).

3. Copyright (life + 60 saal), Patent (20 saal), Trademark (10 saal, renewable), Design (10 + 5 saal), GI (10 saal, renewable), Trade secret (jab tak secret).

4. Plan aur scope, information gathering, risk assessment, testing, analysis, reporting, follow-up (remediation aur re-audit). Figure 4 banao.

5. BCP poore business ko chalta rakhta hai; DR IT systems aur data restore karta hai (BCP ka hissa). RTO restore karne ka maximum allowed time hai; RPO time me naapa gaya maximum acceptable data loss hai.

> **Unit 5 complete! Information Security poora hua.**
> Agar 5 me se 4 ya zyada sahi hue to is subject ke liye tum ready ho. Ab agla: Mobile App Development.